

GOOGLE CLOUD AI SECURITY &amp; GOVERNANCE PLATFORM

# Assurance, Governance & Continuous AI Auditing

End-to-end platform to assess, audit, and harden Enterprise Artificial Intelligence Architectures (GenAI, LLMs, Autonomous Agents & RAG) under global standards **OWASP AISVS v1.0** and **ISO/IEC 42001**.

OWASP AI-SVS V1.0 (12 CHAPTERS)

ISO/IEC 42001:2023

GCP LIVE SCANNER

DUAL INFERENCE ENGINE: GEMINI + OPENROUTER

DEVSECOPS &amp; CI/CD SHIFT-LEFT

## THE PROBLEM TO SOLVE

# The Critical Security Blindspot in Enterprise GenAI Adoption

Enterprises are shipping generative AI models, agentic workflows, and RAG pipelines at breakneck speed, but without architectural verification or auditable controls.



## Accelerated Ungoverned Deployment

Over **80% of enterprise AI projects** enter production without a formal cybersecurity review, leaving novel LLM threat vectors completely uninspected.



## Unprecedented Attack Surface

RAG pipelines and autonomous agents introduce critical attack surfaces: **Indirect Prompt Injection**, **Vector Database Poisoning**, and context window data leaks.



## CISO vs Data Science Silo

Security teams lack domain tools to audit agent graphs and vector embeddings; AI developers frequently lack familiarity with formal compliance standards.

## Lack of Operational Standards

Although frameworks like **OWASP AISVS** and **ISO 42001** exist, organizations lack automated tooling to translate hundreds of theoretical clauses into actionable infrastructure checks.

## Proliferation of "Shadow AI"

Unregulated external API invocations, hardcoded master credentials, missing rate limits, and unencrypted vector storage containing Personally Identifiable Information (PII).

IMPACT OF INACTION

# The Real Cost of Neglecting Proactive Auditing

Operating unverified AI systems causes catastrophic financial, legal, and operational damage.

€35M

or 7% of global annual turnover in statutory EU AI Act penalties

\$4.88M

Average global cost of an enterprise data breach (IBM Security 2024)

10 of 10

Vulnerabilities in OWASP LLM Top 10 present by default omission

100%

Preventable through automated architectural pre-flight scanning

### Exfiltration of Secrets & PII

Prompt injections engineered to dump database connection strings, cloud API keys, or customer confidential records inadvertently ingested into LLM context memory.

### Regulatory Injunctions & Fines

Non-compliance with privacy regulations (GDPR, LFPDPPP) and consumer protection acts (LFPC), triggering statutory audits, mandatory service shutdowns, and litigation.

### Severe Brand & Trust Erosion

Toxic hallucinations in customer-facing assistants and biased automated credit/hiring decisions that permanently destroy market confidence and enterprise valuation.

## OUR SOLUTION

# AegisAI: Comprehensive & Automated AI Assurance

Transforming AI security auditing from weeks of manual guesswork into seconds of algorithmic verification.

## 🛡️ Proactive Shift-Left Security

AegisAI inspects system artifacts (flow diagrams, microservice specifications, prompt configurations, and cloud infrastructure) **before and during** production deployment.

- Granular security control verification across 12 standardized domains.
- Instant identification of non-compliant gaps and severity ratings.
- Zero-trust secret isolation and cryptographic API key masking.

## ⚡ Automated Remediation & Ready Code

We don't merely highlight flaws: AegisAI generates **actionable technical action plans**, hardened architectural diagrams, and drop-in code recipes to fix every vulnerability.

- Copy-paste code recipes in TypeScript, Python, and Google Cloud CLI.
- Step-by-step remediated architecture synthesis.
- Executive PDF report generation ready for certification and audit boards.

## 1. Standardized Diagnostics

Automated benchmarking against OWASP AISVS, ISO 42001, and regional data privacy legislation.

## 2. Live Google Cloud Scanner

Direct telemetry inspection into live GCP environments: Vertex AI, Cloud Run, Secret Manager, and IAM.

## 3. C-Level Visibility

Aggregated security posture dashboards, historical radar charts, and compliance trend telemetry.

COMPLIANCE MATRIX

# Multi-Standard Framework Support & Custom Governance

Native support for the world's most rigorous AI compliance standards alongside Bring-Your-Own-Framework (BYOF) capabilities.

| Standard / Framework      | Technical Scope                                      | Controls Evaluated by AegisAI                                                                                      | Coverage Level      |
|---------------------------|------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------|---------------------|
| OWASP AI-SVS v1.0         | AI Security Verification Standard                    | 12 Complete Chapters: Governance, Supply Chain, Data, Architecture, Model, RAG, Verification & Deployment.         | 100% COMPLETE       |
| ISO/IEC 42001:2023        | Artificial Intelligence Management System (AIMS)     | Clauses 4-10 and Annex A Controls: Ethical impact assessment, risk management lifecycle, and auditable governance. | CERTIFICATION READY |
| Mexican Regulatory (2026) | Consumer Protection (LFPC) & Personal Data (LFPDPPP) | Algorithmic transparency, AI deceptive advertising prevention, ARCO data privacy rights, and explicit consent.     | REGIONAL STATUTORY  |
| BYOF Custom Framework     | Bring Your Own Framework                             | Custom engine enabling organizations to import proprietary internal standards in JSON with weighted controls.      | EXTENSIBLE          |

**Unified Cross-Framework Auditing:** A single system architecture can be audited simultaneously across multiple regulatory frameworks in one pass, generating consolidated posture scores and standard-specific remediations.

## SOFTWARE ARCHITECTURE

# Decoupled, Resilient, and Secure System Architecture

Modular design featuring clean microservices, strict security middleware, and a decoupled multi-provider inference engine.

## 1. Presentation & Frontend

- **React 19 + TypeScript + Vite**
- Tailwind CSS v4 (Aegis Dark System)
- Dynamic charts with **Recharts**
- Client PDF generation with **jsPDF & AutoTable**
- Responsive reactive state & offline fallback

## 2. Backend & API Security

- **Node.js + Express + TypeScript**
- RBAC Middleware (x-admin-token, x-api-key)
- Strict HTTP security headers (CSP, HSTS, CORS)
- Automatic log masking for credentials
- Dual storage: Local JSON + Cloud Firestore

## 3. Inference Engine & GCP Scanner

- **Google Gemini API** (gemini-3.5-flash / 3.8-flash)
- **OpenRouter / OpenAI Proxy** router
- **GCP Live Scanner**: Vertex AI, IAM, Secret Manager, Cloud Run & Storage
- Exponential backoff demand spike resilience

### Zero-Trust Data Sanitization Pipeline:

No customer secrets, database credentials, or private cloud tokens are ever transmitted to the LLM context. AegisAI applies a **Zero-Leak Sanitization Filter** before initiating inference calls, guaranteeing total enterprise IP confidentiality.

## OPERATIONAL EXECUTION

# The Auditor's Workflow: From Vulnerability to Solution

How AegisAI guides security auditors from technical ingestion to end-to-end infrastructure hardening.

- 1 Ingestion & Context Setup**  
Auditor uploads system architecture diagrams, infrastructure specs, or RAG descriptions and chooses evaluation standards.
- 2 Live Cloud Telemetry Scan (Optional)**  
If deployed on Google Cloud, AegisAI scans live Vertex AI models, Storage buckets, and Secret Manager configs.
- 3 Algorithmic AI Verification**  
Inference engine evaluates each sub-control, determines technical compliance, and calculates a 0-100 overall score.
- 4 Interactive Executive Report**  
Real-time radar charts display domain maturity, comparing passed controls against high-priority architectural gaps.
- 5 Action Plan & Code Recipe Generator**  
AegisAI synthesizes exact code recipes (TypeScript, Python, Terraform) to patch every failing control found.
- 6 Formal Export & PDF Download**  
Instant download of auditable PDF reports ready for board reviews, client presentations, or regulatory filings.

ARCHITECTURE SPECS & DEVSECOPS

# System Specifications, Benchmarks & Code Quality

Engineered for production resilience, low latency, and uncompromising DevSecOps standards.

< 3.5s

Average latency per complete 12-chapter architectural audit

100%

Coverage across OWASP LLM Red-Teaming verification suite

0

Leaked credentials or secrets (Strictly verified by git-secrets)

Multi-LLM

Gemini, Claude 3.7, GPT-4o, DeepSeek R1 & Local Ollama

## Infrastructure & Deployment

- **Containerization:** Multi-stage Dockerfile with minimal footprint.
- **Google Cloud Run:** Scale-to-zero serverless deployment on standard port 8080.
- **Secret Manager:** Zero-trust runtime secrets injection.
- **CI/CD Automated Testing:** Pre-commit hooks and regression suites.

## Resilience & Privacy Architecture

- **Automatic Fallbacks:** Exponential backoff for LLM provider saturation.
- **Environment Isolation:** Safe local override support (`*.local.json`).
- **Zero Data Retention:** Customer architectures are never used to train foundational models.
- **Autonomous Demo Mode:** Full offline capabilities without cloud dependencies.

## EVOLUTION &amp; ROADMAP

# Next Horizons in AegisAI Platform Engineering

Our forward-looking roadmap to define the future of autonomous enterprise AI assurance.

## Q4 2026 • NEAR TERM

## Native CI/CD Shift-Left

Official **GitHub Actions** and **GitLab CI Runners** to automatically block pull requests introducing prompt injection vulnerabilities or unencrypted vector storage before merging.

## Q1 2027 • MEDIUM TERM

## Multi-Agent Graph Auditing

Specialized auditing module for complex autonomous agent workflows (LangGraph, CrewAI, AutoGen): tool authorization boundary checks, cycle loop prevention, and inter-agent memory sandboxing.

## Q2 2027 • LONG TERM

## Autonomous IaC Remediation

One-click automated synthesis of **Terraform Modules** and **Helm Charts** that directly apply remediation recipes to GCP, AWS, and Azure clusters without manual configuration.

## 🎯 Conclusion: Security that Accelerates Innovation

AegisAI does not exist to slow down AI adoption; it provides the **architectural certainty, governance, and technical rigor** needed for enterprises to deploy frontier AI systems with complete confidence, safeguarding their assets and fulfilling global compliance.